Information Disclosure Vulnerability Assessment & Security Analysis Report

Vulnerability Details :

Vulnerability Name / Type:
Information Disclosure

Description:
This vulnerability occurs when the web application exposes sensitive information unintentionally. Examples include configuration files, server paths, internal APIs, or debug data. In these labs, the application reveals sensitive data that could assist an attacker in further attacks or reconnaissance.

Impact / Risk:
An attacker can use the disclosed information to gain insight into the system architecture, find potential weaknesses, or plan advanced attacks. Although it may not immediately compromise accounts, it increases the risk of future exploitation.

Lab 1

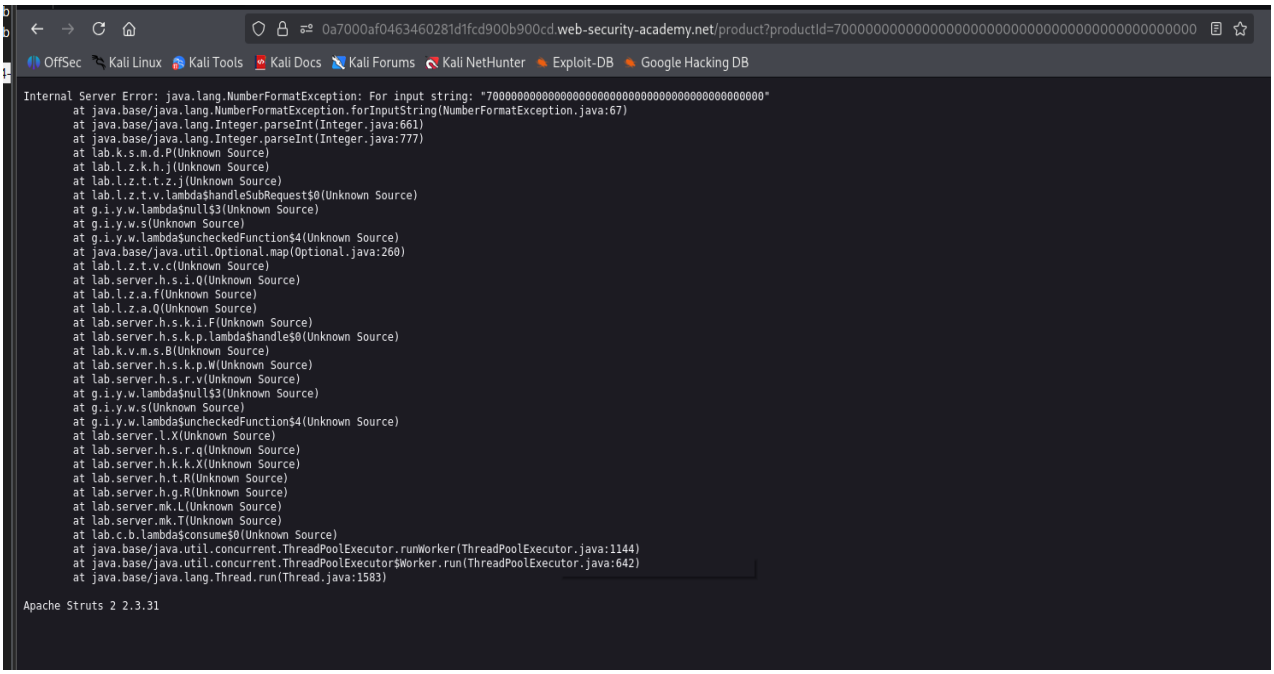
Lab Title:
Information disclosure in error messages

Step 1:

Explanation:

I changed in the URL of one photo, making its parameter a very big number and it give me an error message which has the solution

Screenshot:



Step 2:

Explanation:

By taking the version of the version of the popular Java web application framework which located at the the end of the error message, it seems to be the solution

Screenshot:

Lab 2

Lab Title:

Information disclosure on debug page

Step 1:

Explanation:

By looking in the source code of the home page , it seems to have a strange comment

Screenshot:

```
187                     </div>
188                     <div>
189                         <img src="/image/productcatalog/products/47.jpg">
190                         <h3>3D Voice Assistants</h3>
191                         <img src="/resources/images/rating2.png">
192                         $86.31
193                         <a class="button" href="/product?productId=20">View details</a>
194                     </div>
195                 </section>
196                 <!-- <a href=/cgi-bin/phpinfo.php>Debug</a> -->
197             </div>
198         </section>
199         <div class="footer-wrapper">
200         </div>
201     </div>
202 </body>
203 </html>
```

Step 2:

Explanation:

By adding this the whole URL, it gives me a sheet that would have the solution

Screenshot:

PHP Version 7.4.3-4ubuntu2.29

System	Linux e9a0e950f67b 4.14.355-280.713.amzn2.x86_64 #1 SMP Tue Jan 13 00:31:06 UTC 2026 x86_64
Build Date	Mar 25 2025 18:57:03
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/cgi
Loaded Configuration File	/etc/php/7.4/cgi/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/cgi/conf.d
Additional .ini files parsed	/etc/php/7.4/cgi/conf.d/10-opcache.ini, /etc/php/7.4/cgi/conf.d/10-pdo.ini, /etc/php/7.4/cgi/conf.d/15-xml.ini, /etc/php/7.4/cgi/conf.d/20-calendar.ini, /etc/php/7.4/cgi/conf.d/20-ctype.ini, /etc/php/7.4/cgi/conf.d/20-dom.ini, /etc/php/7.4/cgi/conf.d/20-exif.ini, /etc/php/7.4/cgi/conf.d/20-ffi.ini, /etc/php/7.4/cgi/conf.d/20-fileinfo.ini, /etc/php/7.4/cgi/conf.d/20-ftp.ini, /etc/php/7.4/cgi/conf.d/20-gettext.ini, /etc/php/7.4/cgi/conf.d/20-iconv.ini, /etc/php/7.4/cgi/conf.d/20-json.ini, /etc/php/7.4/cgi/conf.d/20-phar.ini,

Step 3:

By searching for “key” word it gives me a secret key

Screenshot :

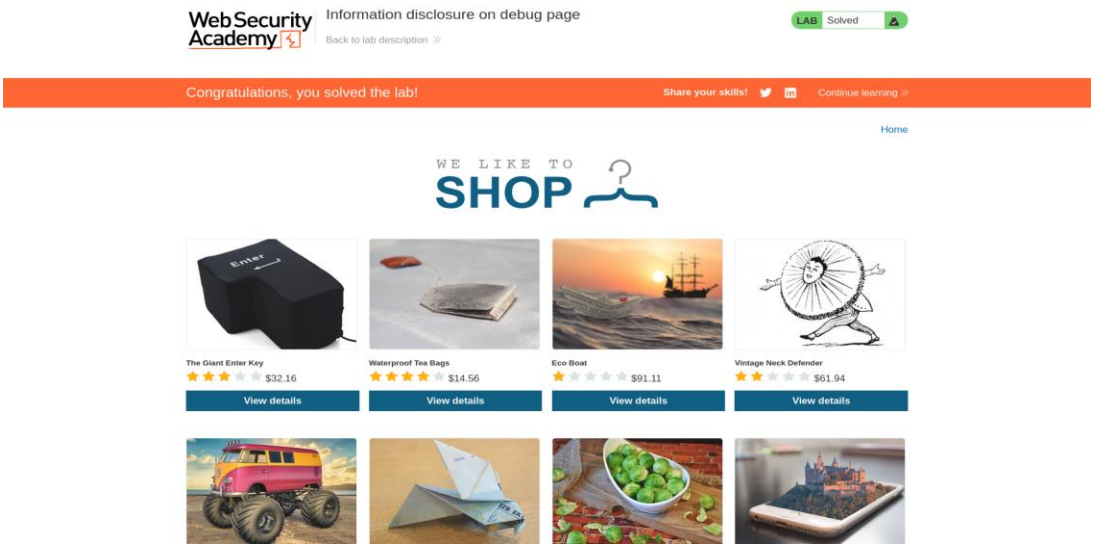
USER	carlos
HTTP_TE	trailers
SECRET_KEY	9trtq6z0wfhsz4qj5b3qw2dxwvz7ol5g
HTTP_SEC_FETCH_USER	?1
QUERY_STRING	no value
HOME	/home/carlos
HTTP_USER_AGENT	Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
HTTP_UPGRADE_INSECURE_REQUESTS	1
HTTP_ACCEPT	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
SCRIPT_FILENAME	/home/carlos/cgi-bin/phpinfo.php
HTTP_HOST	0a2800e503b0900980b92b5d007c000b.web-security-academy.net
SUDO_UID	10000
LOGNAME	carlos
SERVER_SOFTWARE	PortSwiggerHttpServer/1.0
HTTP_SEC_FETCH_MODE	navigate
TERM	unknown
HTTP_COOKIE	session=3lRzvt5f04PyjDvte5RkFUBTUai8W6Qb

key Highlight All Match Case Match Diacritics Whole Words 5 of 6 matches

Step 4:

By submitting this secret key, the lab solved

Screenshot:



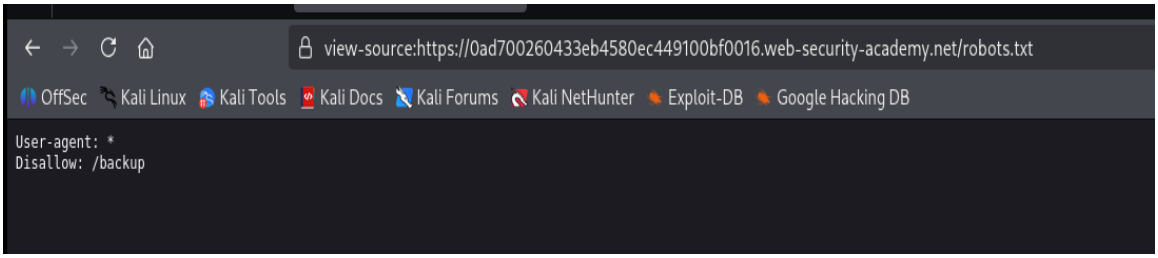
Lab 3:

- **Lab Title:**
  Source code disclosure via backup files

Step 1:

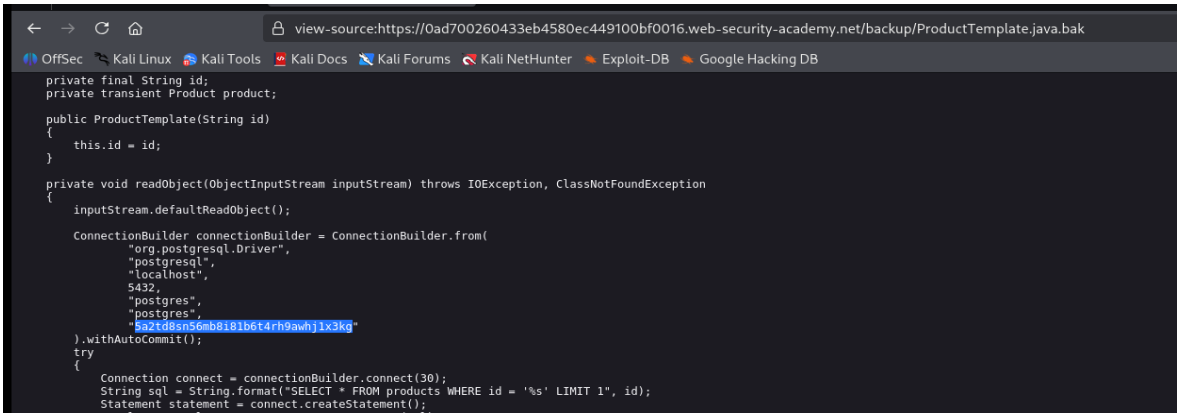
Explanation:
By searching for robots.txt file in the URL, it gives me a User Agent

Screenshot:



Step 2:

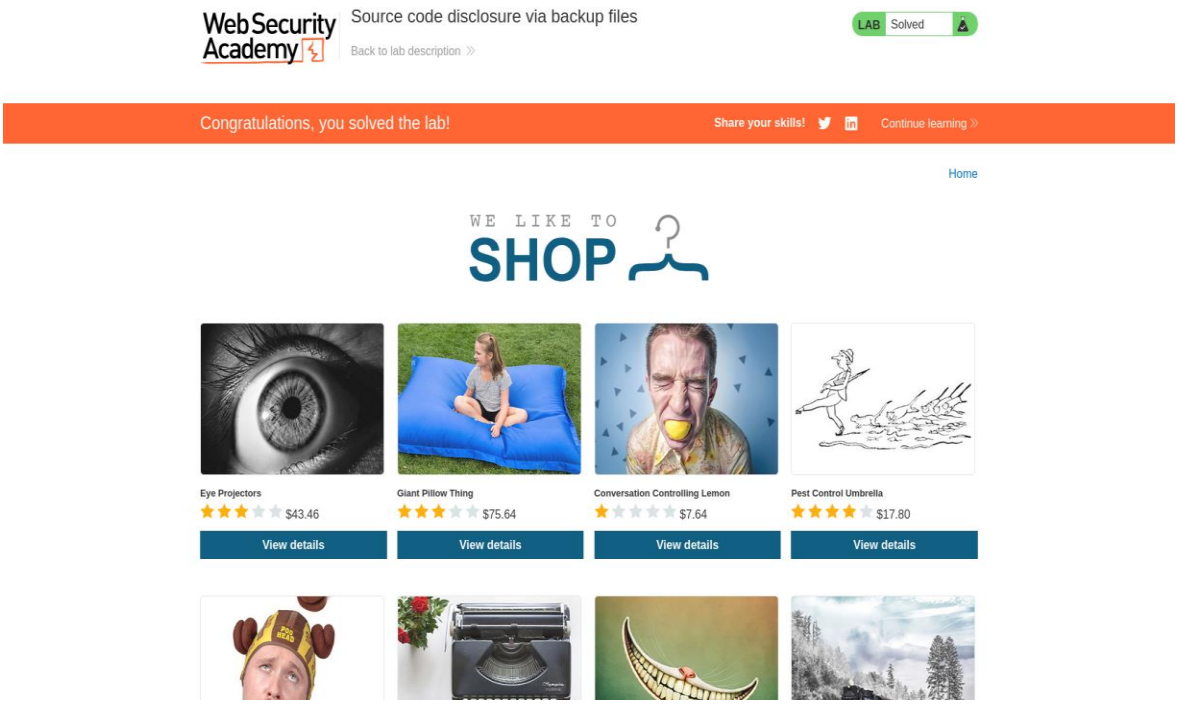
Explanation:
By searching for this user agent, it gives me a java script code which seems to have the secret key , Screenshot:



Step 3:

Explanation:
By submitting it, the lab solved

Screenshot:



Lab 4:

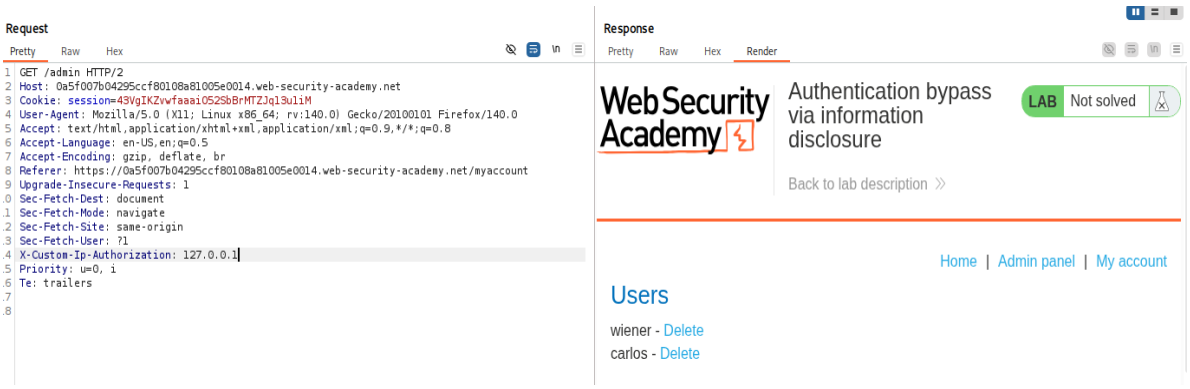
- **Lab Title:**
  Authentication bypass via information disclosure

Step 1:

Explanation:
By taking a login request , changing the redirect location into admin page and adding

this header : X-Custom-IP-Authorization: 127.0.0.1 , the server thinks the request came from **localhost**.

Screenshot:

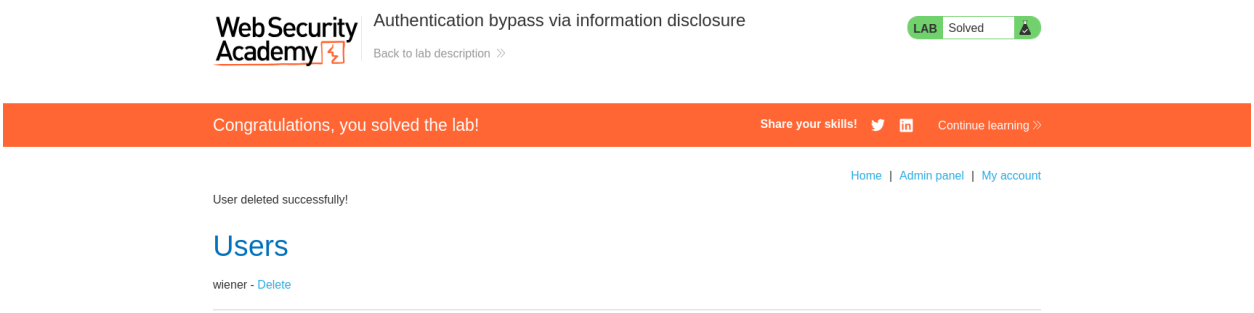


Step 2:

Explanation:

By adding the rest URL: /delete?username=carlos , Carlos deleted successfully

Screenshot:



Lab 5:

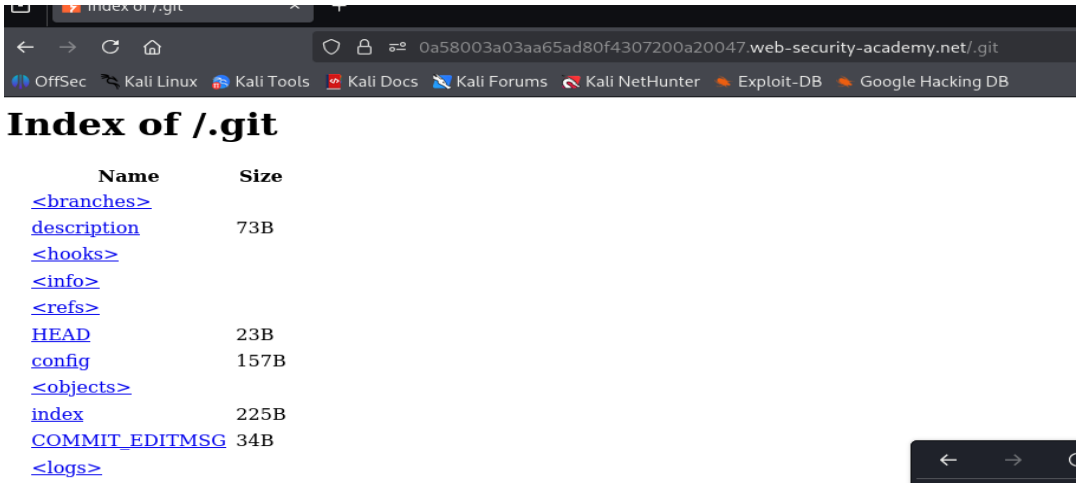
- **Lab Title:**
  Information disclosure in version control history

Step 1:

Explanation:

By adding this index: /.git , the website accidentally exposed a **Git repository, and** These files often reveal **old code, secrets, or headers**.

Screenshot:



Step 2:

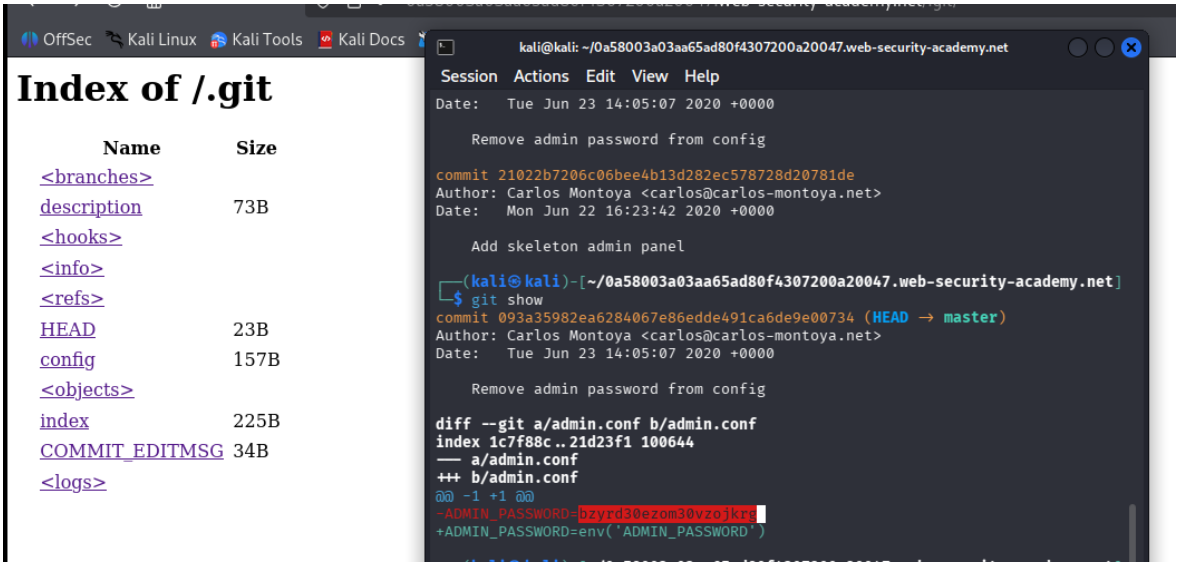
Explanation:

Downloaded a copy of the directory. By using the command:

wget -r https://YOUR-LAB-ID.web-security-academy.net/.git/

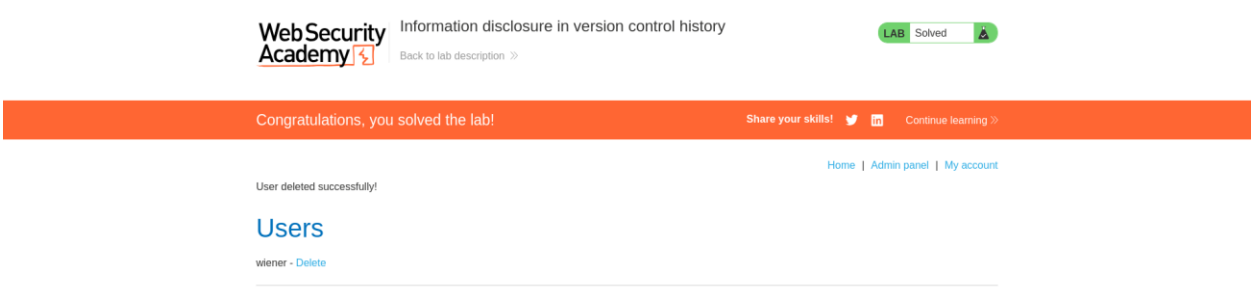
Explore the downloaded directory using your local Git installation and by using some commands, The password appeared

Screenshot:



Step 3:

Explanation:

Try the leaked password and then opened the admin panel and deleted Carlos, so the lab solved

Screenshot: